Politechnika Krakowska
im. Tadeusza Kościuszki

Wydział Informatyki i Matematyki

Wiktor Zmiendak

Numer albumu: 142706

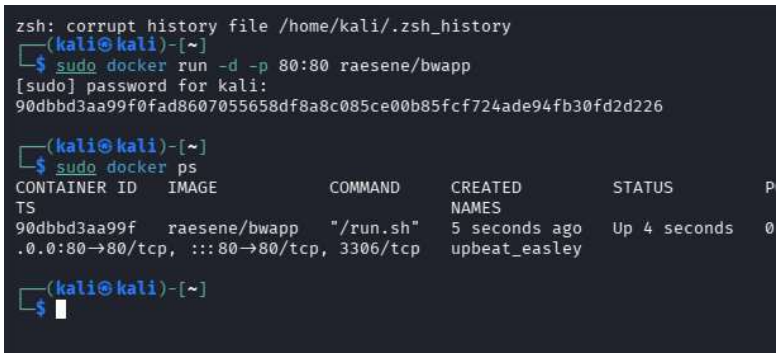
Sprawozdanie

Bezpieczeństwo aplikacji internetowych

Laboratorium nr 9

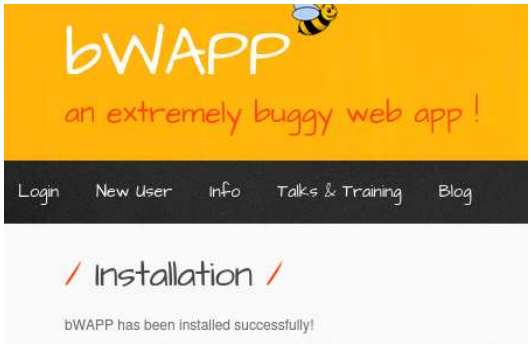
Zadanie 2

Uruchamiamy kontener docker.



Zadanie 3

Instalujemy aplikację bWapp i logujemy się.



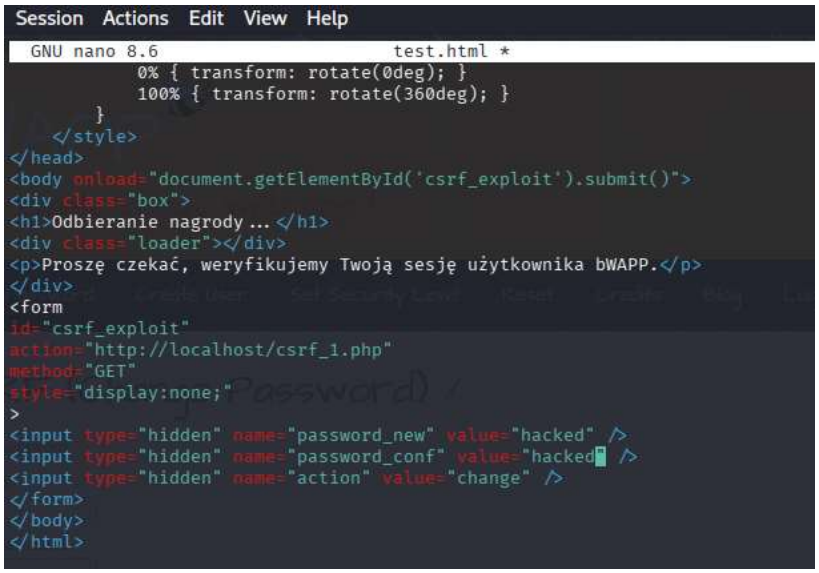
Zadanie 4

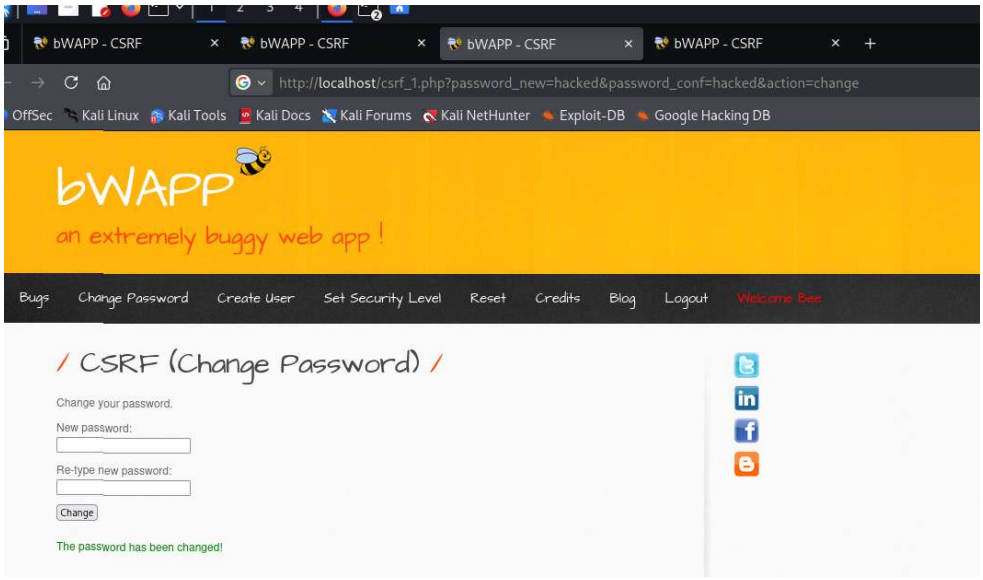
Na poziomie zabezpieczeń Low próbujemy zalogować się na pierwszego użytkownika zapisanego w pliku xml wykorzystując do tego atak Xpath Injection. W tym celu jako login podajemy ciąg *' or 1=1 or ''='* co skutkuje pomyślnym zalogowaniem się na konto użytkownika Neo. Dzieje się tak ponieważ wstrzykując powyższy kod do przetwarzanego zapytania serwer przekształca logikę stojącą za weryfikowanie loginu oraz hasła. Przykładowo fragment *or 1=1* sprawia że cały warunek w polu z loginem i hasłem staje się prawdziwy.



Zadanie 5

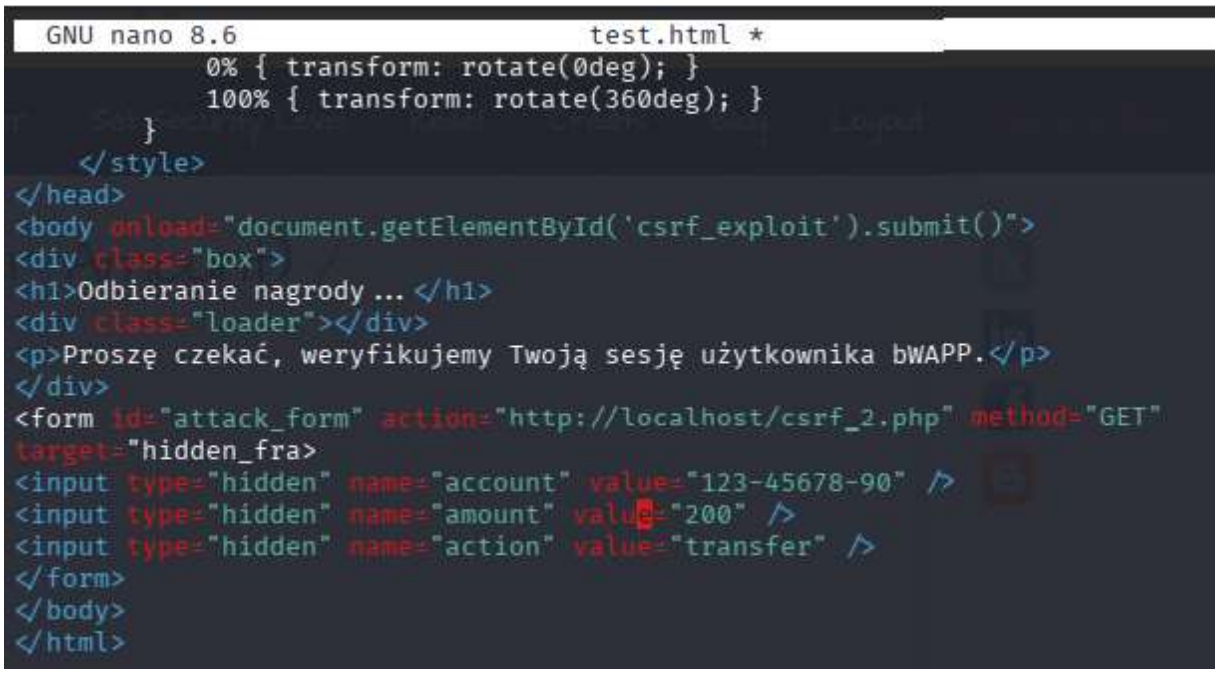
Do przeprowadzenia następnego ataku z użyciem podatności CSRF utworzyliśmy specjalnie przygotowaną stronę html która przekierowuje użytkownika do strony bWapp jednocześnie wstrzykując do formularza zmieniającego hasło swoje własne wartości co skutkuje zmianą hasła na nasze.

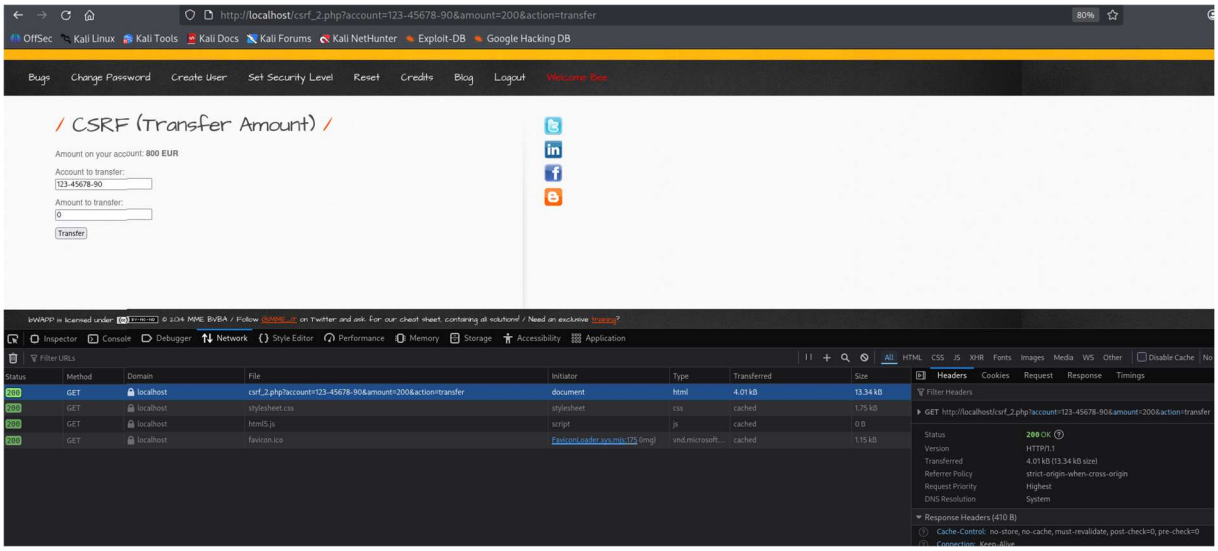




Zadanie 6

W kolejnym ataku ponownie wykorzystujemy podatność CSRF tym razem do przetransferowania na nasze konto 200 Euro. W tym celu modyfikujemy naszą poprzednią stronę tak aby przekierowało nas na odpowiednią stronę w bWappie i automatycznie wprowadziło dane do przelewu do formularza.





Widzimy że z naszego konta ubyło 200 Euro a w konsoli widzimy wywołane zapytanie GET.

Zadanie 7

Usuwamy kontener

